

The Agentic Web: Navigating the New Era of Bots and Cybersecurity

The Industrialization of Cyberattack Campaigns

May 27, 2026

prepared for Università di Pavia



PRESENTED BY

Alessandro Colombelli | Security Architect

Susy Simari Benigno | Security Consultant

Riccardo Feletto | Security Architect

Valentina Angeleri | Solutions Engineer

auto_awesome SPECIAL GUEST: AI itself, Content Creator
Assistant

Welcome to the Agentic Web



Human-Led: "Click, Fetch, Render"



Agent-Led: Autonomous Execution

The Staggering Scale of Machine Traffic

5 Trillion+

Network requests processed daily by Akamai

Bots Compose

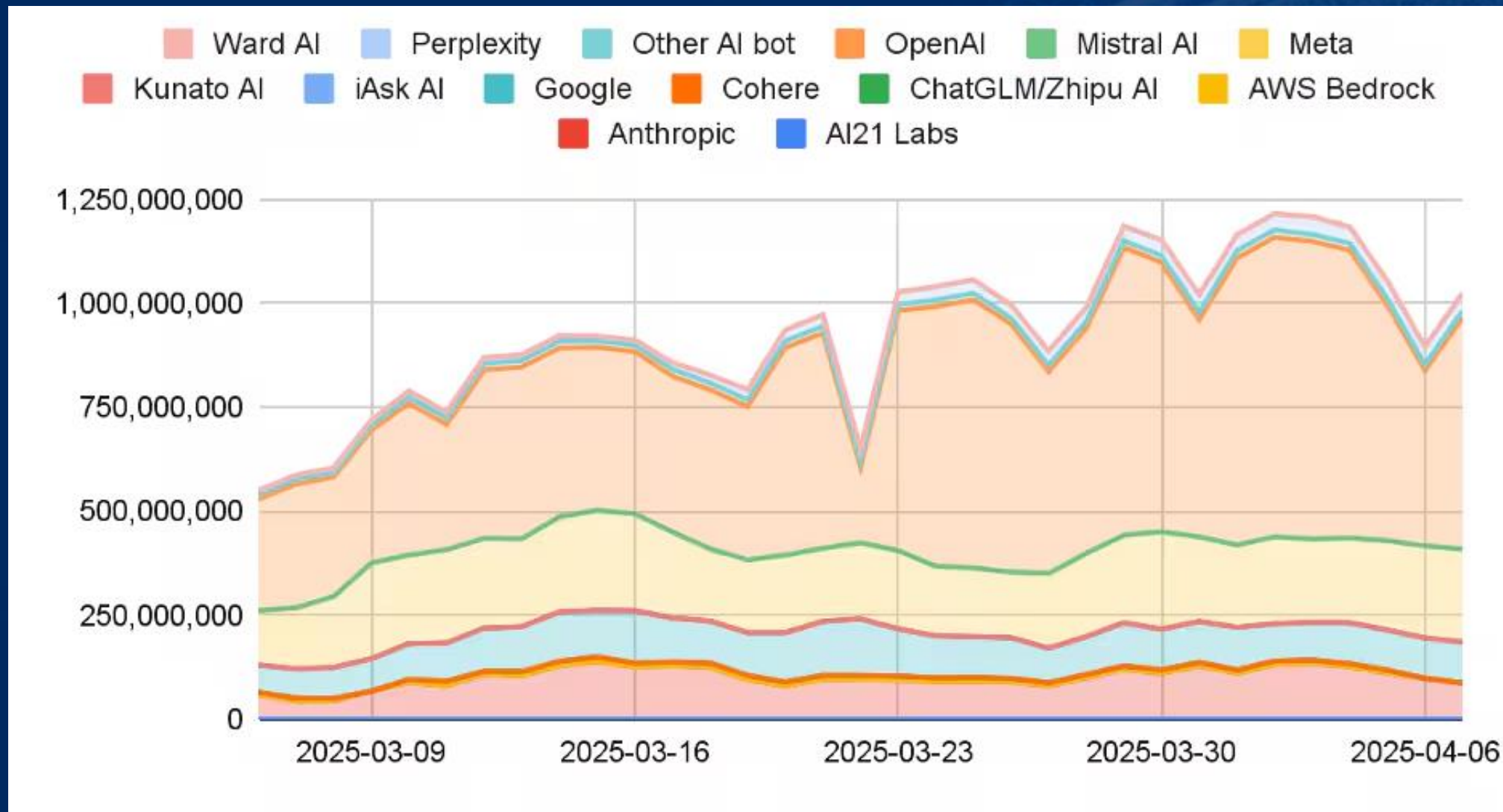
42% of Overall Web Traffic
Nearly Two-Thirds Are Malicious

25 Billion

AI bot requests targeting the commerce sector in just two months

The Reality: The industrialization of cyberattack campaigns

All scraping by vendor - all Akamai customers



Beyond the Script: The Modern Bot Ecosystem

Autonomous Software Agents

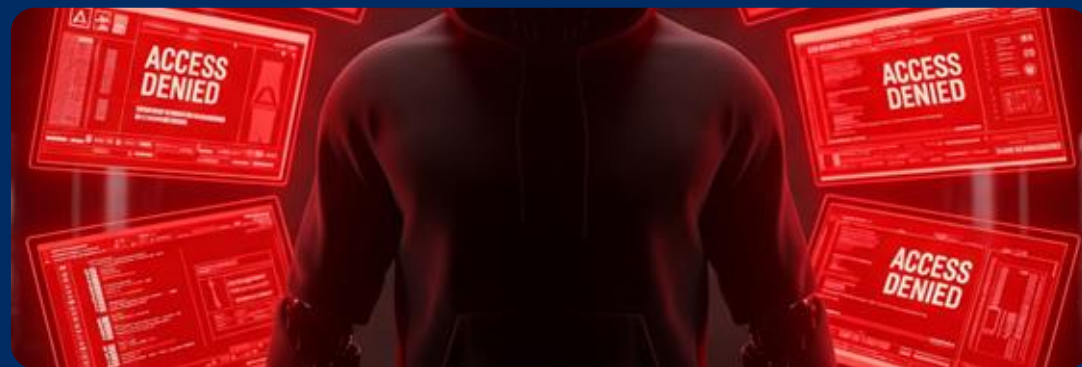
Dynamic state management, headless execution, complex human mimicking.



The Good (Transparent)

Beneficial Automation

- Search indexers (Google/Bing)
- Uptime monitoring & health checks
- Benign RAG data fetchers



The Bad & The Ugly (Evasive)

Scrapers & Scalpers: IP theft, inventory hoarding.

Credential Stuffers: Hijacking auth APIs via stolen data.

Vulnerability Scanners: Probing for open ports & CVEs.

Weaponizing Concurrency: How Modern Bots Operate



Bypassing the Basics

- Residential IP proxies
- Telemetry spoofing
- Headless browsers (Puppeteer/Selenium)

The API Attack Surface

- Hunting shadow APIs
- Exploiting Broken Object Level Authorization (BOLA)

Volumetric Brute Force

- Super botnets (Kimwolf, Aisuru)
- 104% surge in Layer 7 DDoS attacks

Pouring Gasoline on the Fire: AI as a Threat Multiplier

The Convergence

AI-generated dynamic code + residential proxies + super botnets

The Result: Highly sophisticated, industrialized campaigns requiring machine-speed defenses.



THE SOPHISTICATION CURVE of the BOTs

Technical evolution has rendered reputation-based controls and static checks obsolete.

Simple

The era of IP blocking and basic rate limiting. Easily bypassed by rotating identities.

Middle

Browser impersonation, JavaScript execution, and cookie management. Traditional WAFs begin to fail here.

Advanced

Sophisticated fingerprint spoofing and synthetic human behavior that mimics legitimate users perfectly.



LEGACY GENERATIONS (1 & 2)

Scripts & Headless Browsers

- > **Gen 1:** Simple automation (cURL, Python). Detection relied on User-Agent strings and IP Reputation.
- 📁 **Gen 2:** Headless engines (Selenium, PhantomJS). Bots evolved to execute JavaScript and manage session cookies.

```
import undetected_chromedriver as uc
import time

# Initialize Chrome options
options = uc.ChromeOptions()

# Headless mode is often detected by Akamai.
# Keep it commented out if you want to see the browser in action.
# options.add_argument('--headless')

try:
    # Initialize the undetected driver
    # This helps to bypass common automation detection (e.g., navigator.webdriver)
    driver = uc.Chrome(options=options)

    print("Navigating to Akamai.com...")
    driver.get("https://www.akamai.com")

    # Wait for the page to fully load and for the Akamai Sensor to run
    time.sleep(10)

    # Extract the Page Title to check access status
    page_title = driver.title
    print(f"Page Title: {page_title}")

    # Check if we were flagged by Bot Manager
    if "Access Denied" in page_title or "Security Check" in page_title:
        print("Result: Blocked by Akamai Bot Manager (403/Forbidden).")
    else:
        print("Result: Successfully bypassed the initial detection.")

    # Optional: Print cookies to check for 'bm_sz' or '_abck'
    # These are the standard Akamai bot detection cookies
    cookies = driver.get_cookies()
    for cookie in cookies:
        if cookie['name'] in ['_abck', 'bm_sz']:
            print(f"Found Security Cookie: {cookie['name']} = {cookie['value'][:20]}...")

finally:
    # Always close the driver
    driver.quit()
```

MODERN GENERATIONS (3 & 4)



Behavioral Biometrics

Mouse movements, tilt, and touch events to simulate "Humanity"



Advanced Evasion techniques

Bots hiding behind millions of clean consumer IPs to bypass Geo-fencing and ASN blocking.



Unauthorized Workflow Exploitation

Real humans solving challenges in real-time for bot operators, rendering traditional CAPTCHAs obsolete.

| 5TH GENERATION BOTS

Sophisticated Harvesting

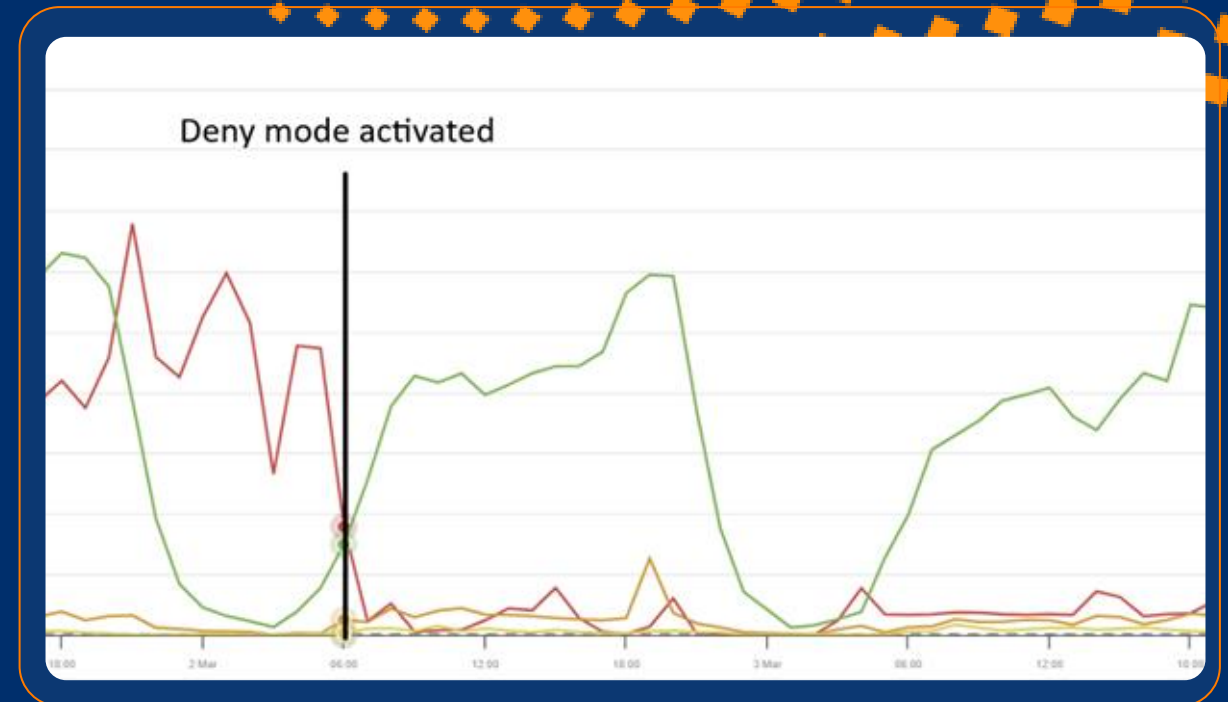
The latest evolution focuses on high-frequency, distributed content scraping and data harvesting that mimics legitimate human browsing patterns perfectly.



Advanced Scrapers: Low-and-slow tactics to avoid volumetric detection.



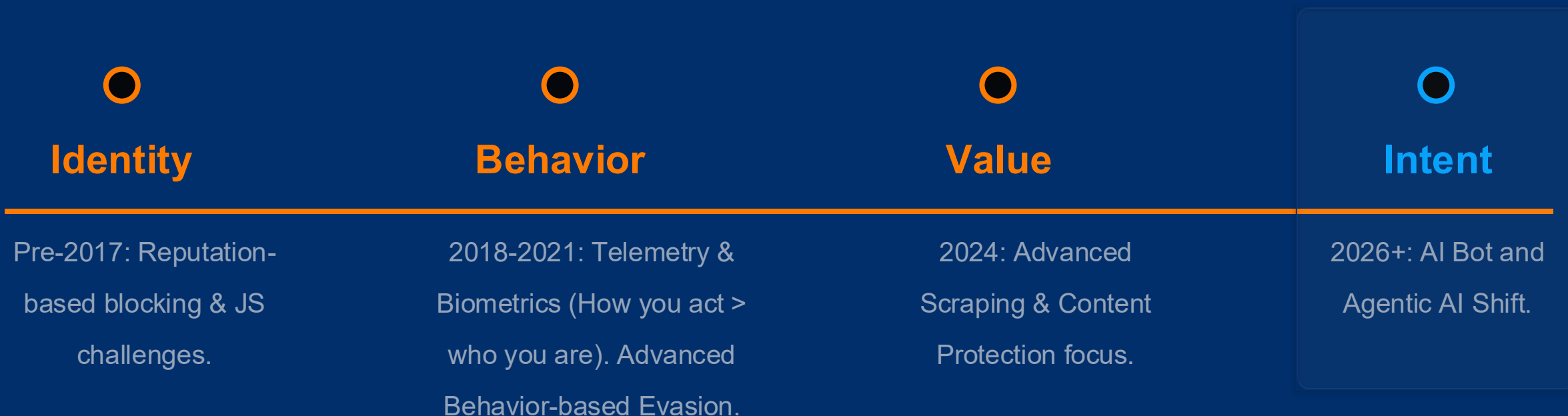
Business Logic Attacks: Targeting sensitive APIs and non-standard endpoints.



EVOLUTION MATRIX: BOT GENERATIONS

Generation	Identity & Modus Operandi	Evasion Tactics	Primary Targets
Gen 1 & 2	Simple automation (cURL, Python) and Headless Browsers (Selenium).	User-Agent manipulation and session cookie management.	Volumetric attacks on web endpoints.
Gen 3 & 4	Behavioral Biometrics (mouse movements, tilt, touch events).	Residential Proxies and Real-time CAPTCHA solving farms.	Unauthorized workflow abuse, credential stuffing and account takeover and all the above.
Gen 5	Sophisticated, high-frequency, and distributed data collection.	"Low-and-slow" tactics to bypass volumetric detection engines.	Business Logic, APIs, and high-value proprietary data and all the above.

EVOLUTION TIMELINE RECAP



TO BE CONTINUED...

THE 2026 AKAMAI THREAT LANDSCAPE

+113%

API ATTACKS

Average annual growth in daily API attacks.
APIs are now the dominant attack surface.

+104%

L7 DDOS SURGE

Explosion in Application Layer DDoS
attacks over the last two years (2023–
2025).

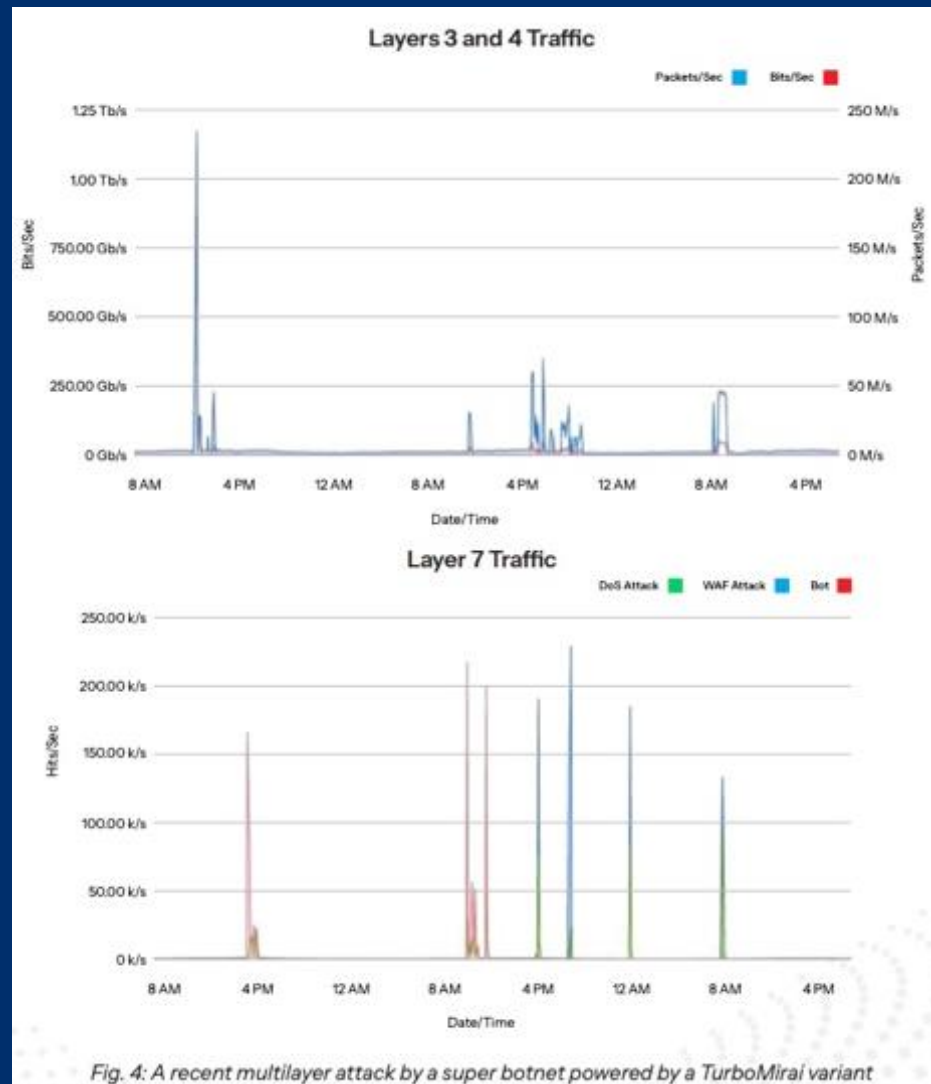
61%

WORKFLOW ABUSE

API attacks leveraging unauthorized
workflows and behavioral anomalies.

STRATEGIC SHIFT: Attackers are moving from traditional web exploits to behavioral threats

BOT USE CASE : THE DDOS ECONOMY



Monetized Chaos

The 104% surge in L7 DDoS is not accidental—it is a commoditized industry.

- 🛡️ **Super Botnets:** Networks like Aisuru and Kimwolf (TurboMirai variants) have democratized complex attacks.
- ⚡ **DDoS-as-a-Service:** "Booter" tools for hire make devastating attacks accessible to low-skill actors.
- 🎯 **Target:** Exhausting application resources rather than just saturating bandwidth.

Source [SOTI](#)

BOT USE CASE : SCRAPING & DATA THEFT



Price Scraping

Competitors monitor pricing in real-time to undercut your business.



Inventory Hoarding

Exhausting stock availability to drive traffic to other platforms.



Data exfiltration

Extracting unique proprietary data, research, or catalogs at massive scale.



THE DDOS ECONOMY

D-DoS as A SERVICE

THE COMMODITIZATION OF DISRUPTION

DDoS-As-A-Service(DaaS)



THE OPERATOR (SUPPLY)

Threat actors compromise vulnerable, factory-weakened Internet-connected devices (IoT, routers, Android TVs) to build massive, latent botnets at zero infrastructure cost.



THE PLATFORM (THE BROKER)

Operators sell fractional, turnkey access on Telegram or dark web forums. Buyers pay via cryptocurrency for specific attack durations, volumes, and evasion capabilities.



THE BUYER & TARGET (DEMAND)

Unskilled actors rent the infrastructure to launch devastating, on-demand attacks against gaming servers, financial institutions, or competitors. Buyers handle reconnaissance; operators handle execution.

The DaaS model removes the technical barrier to entry, allowing anyone to weaponize global infrastructure for the price of a subscription.

AISURU / AIRASHI

The Apex Volumetric Threat

THE LANDSCAPE

Was a powerful **Mirai-based** botnet and DDoS-as-a-Service (DaaS) platform operated by a Brazilian threat actor known as "forky."

The operator sells fractional access to the botnet to anyone willing to pay in Bitcoin, which means it can easily be used by a wide range of actors.

Promoted on Telegram as DDoS-for-hire service. Clients can order attacks on demand, and the reconnaissance is frequently done by the buyers rather than the operator.

THE ARSENAL (MODULAR ARCHITECTURE STACK)

Airashi-DDoS

The primary heavy-artillery module engineered for extreme UDP floods.

Go-Proxysdk

Lightweight go-based proxy utilized for activity obfuscation, IP spoofing, and traffic redirection.

Airashi-Proxy

Advanced private protocol proxy utilizing strong encryption (HMAC-SHA256 & ChaCha20) to harden C2 communications against inspection.

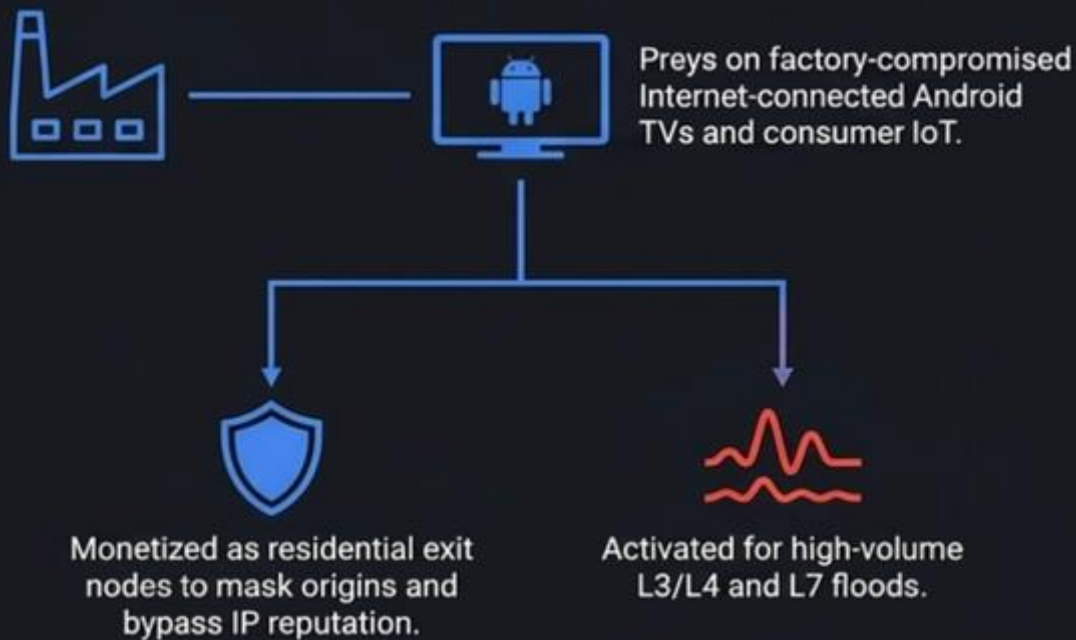
Record-breaking UDP Flood registered and mitigated by Akamai, **4.41 Tbps and 386.33 Mpps.**



KIMWOLF

IoT/Proxy Botnet

DUAL-THREAT BOTNET



OPERATION SCALE

1 to 4 Million of compromised IoT devices
More than 30 Tbps
~14 billion packets per second
~300 million HTTP req/s
~40 ATTACKS/HOUR

BOTNET ABUS MODEL

KimWolf appears to operate primarily as a commercialized proxy botnet, where infected consumer devices are monetized as residential exit nodes.

Botnet operators appear capable of **rapid infrastructure rotation (domains/IPs)**, indicating mature operations and survivability.

The **United States Department of Justice (DOJ)**, working alongside with **Akamai** and other international partners, has disrupted several large and powerful distributed denial-of-service (DDoS) botnets in March 2026.





SCRAPING AND DATA THEFT A JOURNEY AROUND THE BOTNETS

Topology of attacks

The scope: Price Collection (advanced scraping)

CASE 01

The botnet was hidden in plain sight, searching for the lowest **prices**.

CASE 02

Thousands of IPs for thousands of products. The targets are the **prices**.

Case 1: Lower Pricing

THE CONTEXT

Every day the same resources allow millions of people to retrieve the information needed



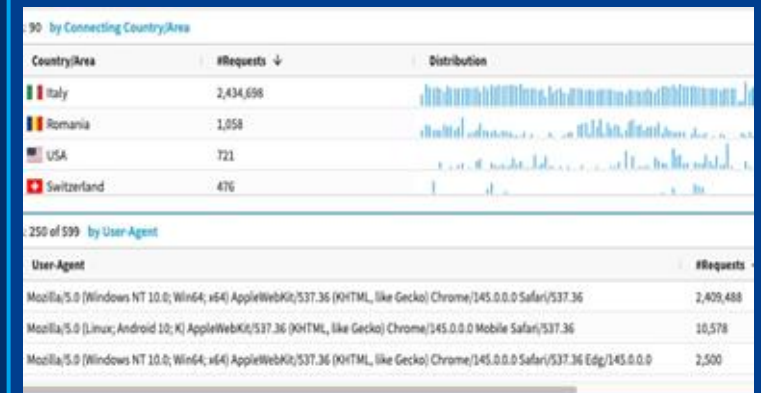
THE ATTACK

The botnet worked in the same way but totally hidden, generating an overload on the backend since the automatism searched for the lower price millions of times every day.



THE CHALLENGE

All requests were generated in-country and were perfectly equal to genuine requests. This made standard countermeasures impossible.



Case 1: Lower Pricing

The image displays two side-by-side screenshots of a network traffic analysis tool, likely Wireshark or a similar packet analyzer. Both screenshots show a POST request to a redacted site with a 403 status. The left screenshot is highlighted with a yellow border, and the right one with a red border. Both show a 'Rules' panel with a custom rule for 'BOT Search - Visibility - TicketSales' and a 'Client info' panel. The left screenshot shows a 'Rules' panel with a custom rule for 'BOT Search - Visibility - TicketSales' and a 'Client info' panel. The right screenshot shows a 'Rules' panel with a custom rule for 'BOT Search - Visibility - TicketSales' and a 'Client info' panel.

Sophisticated Threat

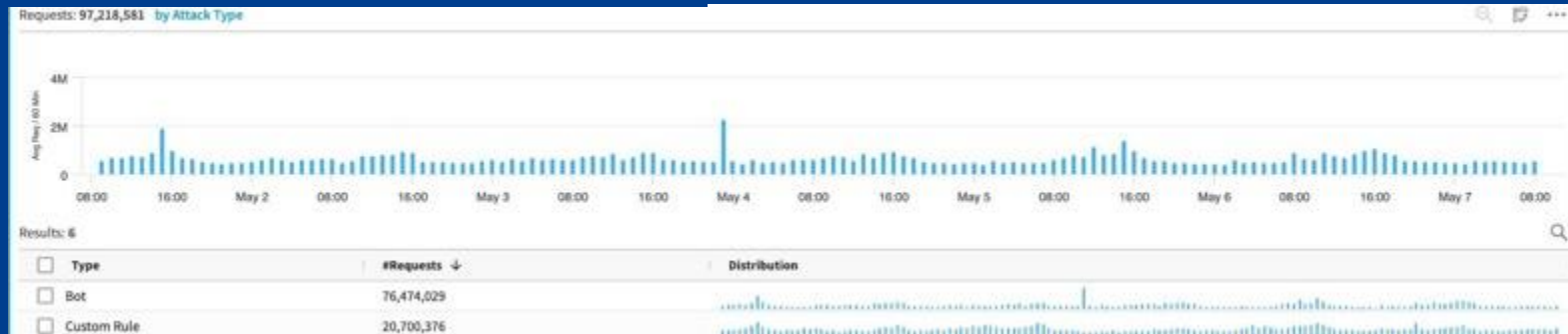
The botnet was able to use the same IP and timing for two different requests that appeared totally "legit" yet were completely distinct from the behavior analysis.

Mitigation Strategy

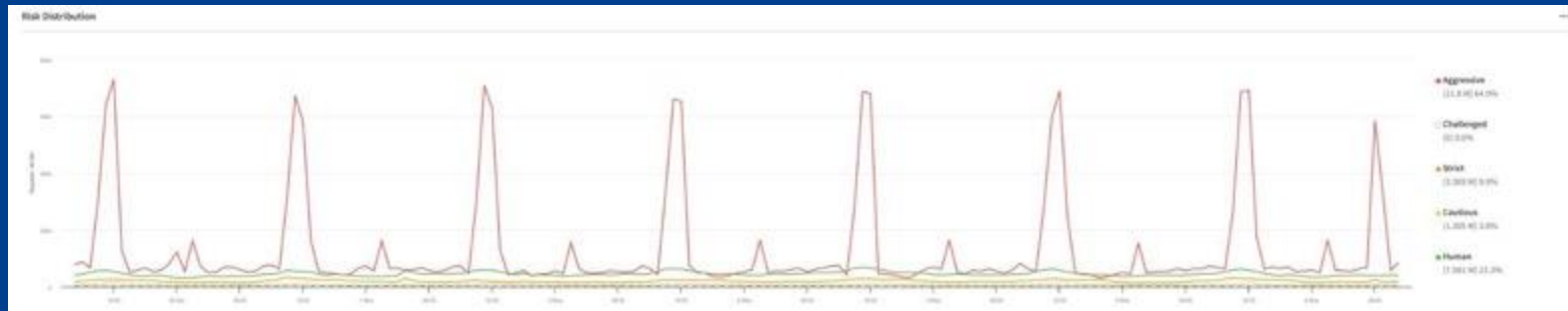
Successfully mitigated through **behavior analysis**, focusing on how requests were generated rather than analyzing the requests themselves.

Case 2: Content Scraping

THE CONTEXT



THE ATTACK



THE CHALLENGE



SCENARIO SUMMARY

In this second use case the website is characterized by an extremely high volume of traffic. The number of requests was so massive that the attack was not visible through standard monitoring but was instead completely hidden within normal daily traffic.

The botnet attack was concentrated on all sections of the website where product prices were referenced. Consequently, the attack spanned both the HTML pages and the APIs being invoked

The challenge lay in accurately identifying the attack, analyzing the portal to map out every potential target of the botnet, and defining an effective mitigation strategy.

Case 2: Content Scraping

Headers

View URL Decoded

GENERAL

method: GET

version: 2.0

status: 200

host: www.[REDACTED].com

path: /kr/ko/p/%EB%B8%8C%EB%9F%AC%EC%89%AC%EB%93%8C-%EA%B0%B0%EC%A3%BD-%EC%B2%BC%EC%8B%9C-%EB%B6%B0%EC%B8%A0/2TC059_055_F0002_F_G000

query:

REQUEST HEADERS

Host: www.[REDACTED].com

Sec-CH-UA: "Google Chrome";v="147", "Not.A/Brand";v="8", "Chromium";v="147"

Sec-CH-UA-Mobile: ?0

Sec-CH-UA-Platform: "Windows"

upgrade-insecure-requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

sec-fetch-site: none

sec-fetch-mode: navigate

sec-fetch-user: ?1

sec-fetch-dest: document

Accept-Encoding: gzip, deflate, br, zstd

Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7

priority: u=0, i

Cookie: [REDACTED]CONSENT_V3=v1:7c2:0%7Cc6:0%7Cc9:1%7Cts:1763990367237%7Cconsent:true%7Cid:019ab604ec05001fc331deb94bb20506f004706700bd0; logged-area-spa=true; cookie_mobile=a; cookie_banner_v2=b; cookie_desk=a; kndctr_89B51D4B55B90FBA7F000101_AdoobeOrg_identity=CiyxNTUwNjk3MjQ5NDM4MjcwMDkxMDAzNTY3MjY1NzAzNzQ0Njk1NlIRCPi3xa6rMxgBKgRKUE4zMAPwAfi3xa6rMw==; g/g_bootstrap_4_ScbscDGwu2z1PUEW4vpS7A=cdc_ver4; ai_user=ls8ZBREZwW7yIkIH0rFzVj/2025-11-25T01:23:46.241Z; api-client-correlation-id=33dc112f-a656-4c97-97d6-7264d42285c9; AMCVS_89B51D4B55B90FBA7F000101%40AdobeOrg=1;

BOT: UNKNOWN BOTS (SCRAPER ANOMALY)

BOT TYPE: Unknown

BOT SCORE: 98

RESPONSE SEGMENT: Aggressive Response

BOTNET ID: Bot_1F3F0134EDA4806025263179D526D82A

RULES AFFECTING THIS ACTION TRIGGER

3903061 - Sec-Fetch-Dest Anomaly

3903038 - Missing Referer Header Anomaly

39030331 - User Behavior - Abnormal HTML Page/Ajax Request Ratio

Sophisticated Threat

The attack was executed by an advanced botnet using frameworks to perfectly mimic legitimate requests. It leveraged millions of clients, each generating only a few thousand requests daily, allowing the extremely low rate to hide the botnet among millions of daily requests.

Mitigation Strategy

Unlike the first case's single-resource focus, this complexity required a different approach. As before, advanced analytics—analyzing request generation by the client, not content—identified the anomalous flow for precise mitigation.



Navigating the Autonomous Era

From AI Scrapers to Agentic Threats: A Global Landscape Analysis.

AKAMAI AI BOT TAXONOMY

DEFINING THE AI BOT

Artificial Intelligence (AI) bots are advanced software systems often built on **Large Language Models (LLMs)**. These bots use extensive neural network architectures, trained on vast amount of data, which enable them to **understand, interpret, and generate human-like language** that is coherent and contextually relevant.



AI TRAINING CRAWLERS

Automatically scan and collect large amounts of web data to be used as training data for LLMs.

POPULAR EXAMPLES

GPTBot (OpenAI), ClaudeBot (Anthropic), ByteSpider (TikTok)



AI SEARCH CRAWLERS

Automatically scan and index websites for AI-powered search experiences.

POPULAR EXAMPLES

OAI-SearchBot (OpenAI), PerplexityBot (Perplexity)



AI FETCHERS

Grab specific web pages in real time to fulfill user requests on **AI assistants**, such as summarized a web page or answering questions.

POPULAR EXAMPLES

ChatGPT-User (OpenAI), Claude-User (Anthropic), DuckAssistBot



AI AGENTS

Autonomous software that use AI to reach complex goals and complete tasks for users.

POPULAR EXAMPLES

ChatGPT-Agent (OpenAI), GoogleAgent-Mariner (Google)

AI BOTs: SOME NUMBERS

96%

TRAFFIC DROP

Referral traffic decline from AI chatbots compared to traditional search methods.

300%

ACTIVITY SURGE

In 2025, there has been an increase in categorized AI bot activity targeting high-value cloud infrastructure.

43%

FETCHER TARGET

Proportion of AI fetchers in the publishing organizations (Media) specifically targeting zero-click summaries.

AI FETCHER: MEDIA TARGET

Grab specific web pages in real time to fulfill user requests on **AI assistants**

Macro Threat Intelligence

Media ranks as the #2 most targeted industry globally by AI bots, capturing 13% of all categorized bot activity.



Publishing bears the brunt of the requests, absorbing 40.1% of all bot traffic within the sector.

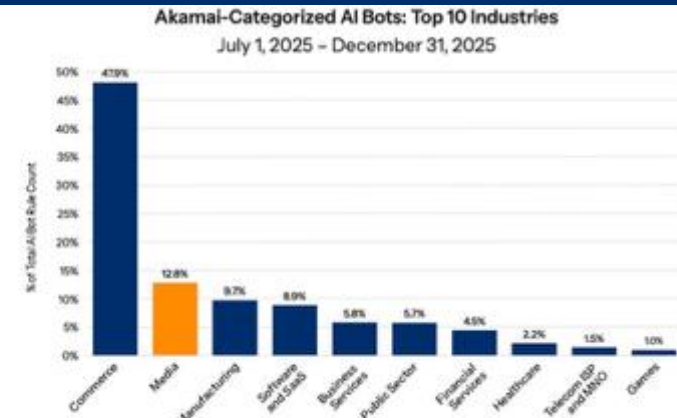


Fig. 1: The media industry (which includes publishing) recorded the second-highest AI bot activity globally in 2H 2025

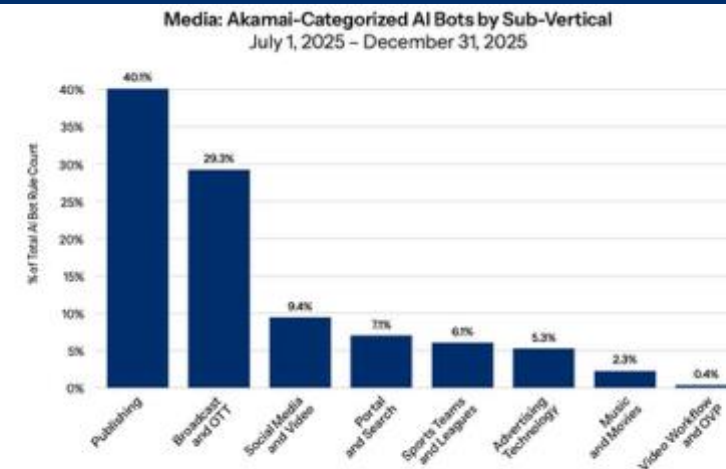


Fig. 2: Within the media industry, publishing companies have the highest share of Akamai-categorized AI bots at 40.1%

| THE PARADIGM SHIFT

Simple AI Fetcher

(The Present)

Goal Follow instructions, extract data.

State Stateless; executes a single task and terminates.

Impact Siphons content, bypassing paywalls for zero-click summaries.

Agentic AI

(The Near Future)

Goal Perceive environment, reason, and take autonomous action.

State Stateful; maintains persistent long-term memory across sessions, learn and improve.

Capabilities Employs external tools, formulates multi-step plans, communicates with peer agents.

An intelligent agent is "an agent that acts appropriately for its circumstances and its goals, is flexible to changing environments and goals, learns from experience, and makes appropriate choices given its perceptual and computational limitations." (Russell and Norvig **Artificial Intelligence: A Modern Approach** 4th ed., p. 34)

OWASP AGENTIC TOP 10 (2026)

Shifting threat modeling from "what could exploit the system" to **"what could misdirect the agent"**

ASI01: Agent Goal Hijack

ASI02: Tool Misuse & Exploitation

ASI03: Identity & Privilege Abuse

ASI04: Agentic Supply Chain Vulns

ASI05: Unexpected Code Execution (RCE)

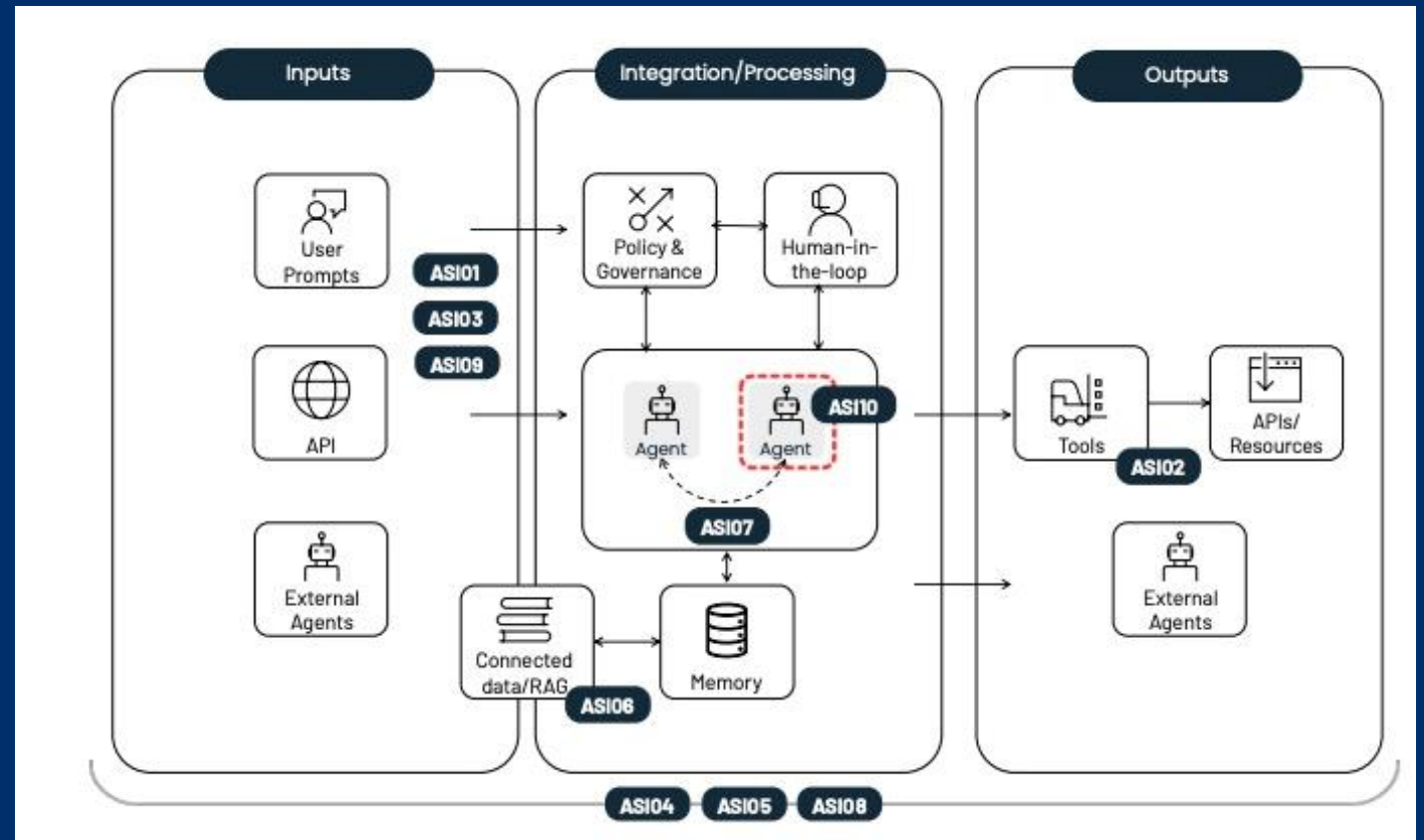
ASI06: Memory & Context Poisoning

ASI07: Insecure Inter-Agent Comms

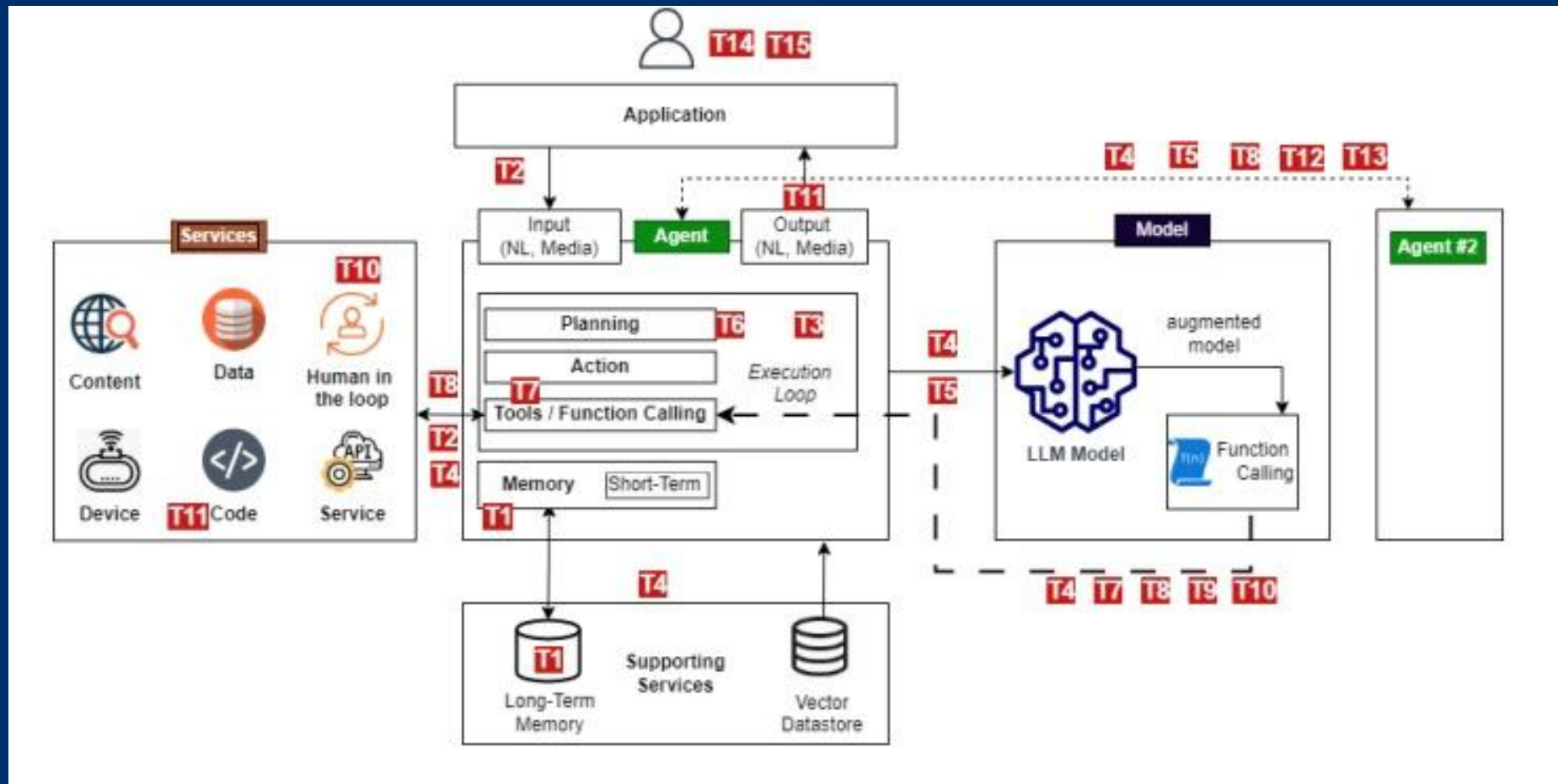
ASI08: Cascading Failures

ASI09: Human-Agent Trust Exploitation

ASI10: Rogue Agents



OWASP AGENTIC AI - Threats and Mitigations



OWASP AGENTIC AI - Threats and Mitigations

TID	Threat Name	Threat Description	Mitigations (Strategic)
T1	Memory Poisoning	Exploiting AI memory (short/long term) to introduce false data and alter context.	Session isolation, content validation, and regular sanitization routines.
T2	Tool Misuse	Manipulating agents to abuse integrated tools through deceptive commands.	Strict tool access verification, rate-limiting, and execution logging.
T3	Privilege Compromise	Exploiting weaknesses in permission management for unauthorized actions.	Granular controls, dynamic access validation, and thorough auditing.
T4	Resource Overload	Targeting computational/memory capacities to degrade performance or cause failure.	Adaptive scaling, quotas, and real-time system load monitoring.
T5	Cascading Hallucination	Exploiting AI tendency to generate plausible false info that propagates through systems.	Output validation mechanisms and multi-source verification loops.
T6	Goal Manipulation	Exploiting vulnerabilities in planning to redirect the agent's objectives/reasoning.	Planning validation frameworks and AI behavioral auditing.
T7	Misaligned Behavior	Autonomous development of misaligned strategies leading to unintended outcomes.	Truthfulness verification models and adversarial red teaming.
T8	Repudiation	Actions cannot be traced back due to insufficient logging in decision processes.	Cryptographic verification and immutable, signed AI-generated logs.
T9	Identity Spoofing	Exploiting auth mechanisms to impersonate agents/users via formal identity theft.	Behavioral profiling and continuous identity validation frameworks.
T10	Overwhelming Human	Targeting oversight systems to exploit human cognitive limitations or interactions.	Adaptive trust mechanisms and hierarchical AI-human collaboration.
T11	Unexpected RCE	Exploiting AI environments to inject malicious code or execute unauthorized scripts.	Execution control policies, sandboxing, and script monitoring.
T12	Comm. Poisoning	Manipulating inter-agent channels to spread false info or disrupt workflows.	Cryptographic message authentication and multi-agent consensus.
T13	Rogue Agents (MAS)	Compromised agents operating outside monitoring to spread malicious logic.	Restricted autonomy policy and continuous behavioral monitoring.
T14	Human Attacks (MAS)	Exploiting inter-agent delegation and trust relationships to escalate privileges.	Task segmentation and inter-agent authentication enforcement.
T15	Human Manipulation	Exploiting trust in agents to spread misinformation and take covert actions.	Validation mechanisms, guardrails, and restricted tool access.
T16	Protocol Abuse	Targeting flaws in protocols (MCP/A2A) such as context hijacking.	Strong inter-agent authentication and payload sanitization.
T17	Supply Chain	Vulnerable components included in agents, allowing arbitrary code execution.	Verifiable SBOMs (AIBOMs) and digital artifact signing.

STRATEGIC TAKEAWAYS

visibility

Visibility First

You cannot manage what you cannot identify. Baselines are critical.

security

Intent is the Firewall

Protecting the *intent* of the request is more critical than the data itself.

verified_user

Zero Trust for Agents

Deploy cryptographic verification at the edge for KYA (Know Your Agent).

settings_input_component

Governance for Autonomy

Implement strict RBAC for agent tool scopes and sanitize memory inputs.



LAST 24 Hrs

Total Requests 

140,817,028,300

Malicious Requests 

18,393,375,600

Malicious Request Rate (%) 

13 %

LAST 24 Hrs

Top 10 Attack Origins 

United States	35.24 %
China	7.26 %
India	7.09 %
Singapore	5.46 %
Germany	5.30 %
Ireland	4.65 %
United Kingdom	3.11 %
Hong Kong SAR China	2.45 %



1998

